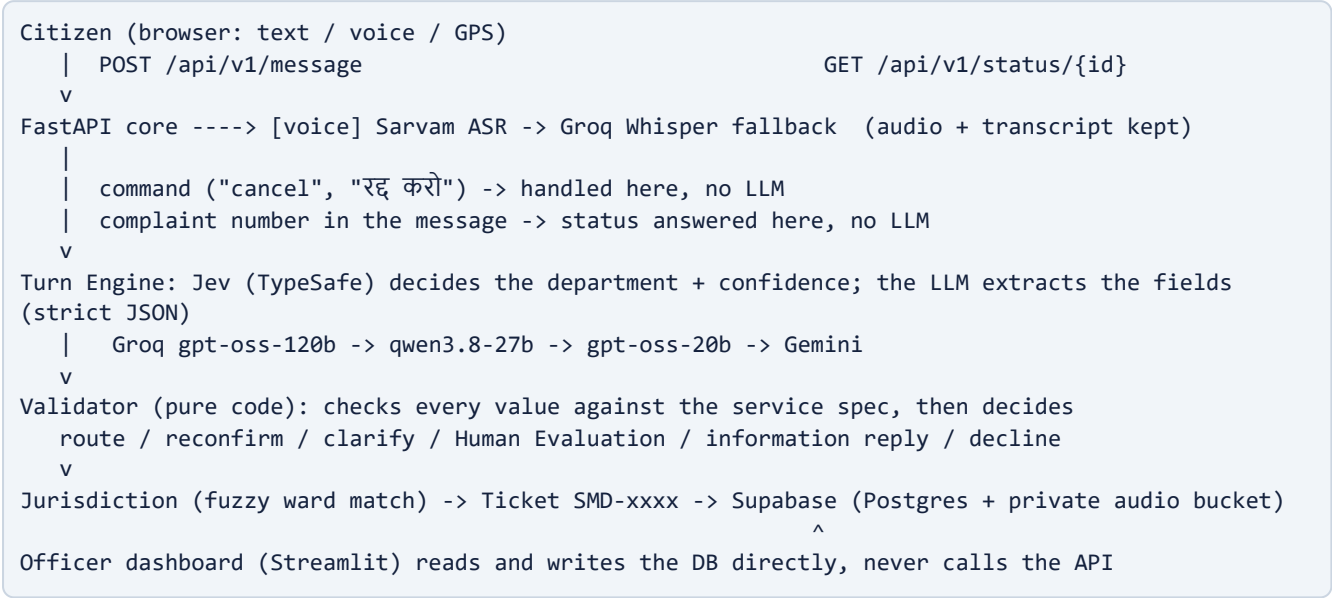


Technology Architecture, Security and Scalability

Samadhan (समाधान)

1. Architecture



Design rules

- Routing happens in the core, not in the website.
- The website talks only to the API and holds no keys.
- The LLM never invents a service, field, department or office. The service spec YAML is the only source.
- The dashboard only shows stored data.
- Timeouts: speech about 8 s, LLM about 6 s, then the next provider in the chain.

Stack

Layer	Choice
Backend	Python 3.12, uv, FastAPI, Uvicorn, Pydantic, httpx, PyYAML, RapidFuzz
Decision model	Jev (TypeSafe): picks the department from a registry of 49 departments; falls back to the LLM path if unreachable
LLM	Groq (openai/gpt-oss-120b , qwen/qwen3.8-27b , openai/gpt-oss-20b), Gemini as last fallback
Voice	Sarvam saaras:v4 (speech-to-text), bulbul:v3 (text-to-speech); Groq whisper-large-v3-turbo fallback
Data	Supabase Postgres with Row Level Security; private Storage bucket audio
Website	HTML, CSS, vanilla JavaScript; MediaRecorder and Geolocation browser APIs; no framework or third-party scripts
Dashboard	Streamlit, pandas, folium and streamlit-folium (OpenStreetMap tiles)
Tooling and hosting	pytest, Ruff, Docker; Render (API, website and dashboard)

Contracts. The API (docs/specs/S01), database (S02) and service spec format (S03) are written specs matched by code (backend/app/schemas.py , database/schema.sql , specs/*.yaml). Endpoints: POST /api/v1/message , GET /api/v1/status/{complaint_id} , GET /health , plus POST /api/v1/speak for voice replies.

2. Security

Area	What is in place
Secrets	Only in .env or host secrets; never committed; .env.example lists names only; the website holds no database keys
Database	Row Level Security on every table with default grants revoked. The public (anon) key has zero access, verified live: a 401 permission denied , not merely an empty result
Service key	Server-side only (API and dashboard)
Audio	Private bucket, reached only through short-lived signed URLs
CORS	Only origins in ALLOWED_ORIGINS
Status endpoint	Returns only complaint ID, status, department and updated time. Never the transcript, audio, location or collected details
Citizen data	Mobile-number login before filing (a demo PIN stands in for SMS OTP for now); the number lets the officer call back; original audio and transcript kept unchanged
LLM safety	Output validated with Pydantic and against the service spec; unknown values dropped; information replies are fixed text plus a link that must be an https .gov.in host that resolves in DNS
Duplicates	A repeated message ID returns the stored response (database key), so retries never create a second ticket
Dashboard	Password login

Known gaps (honest). One shared officer password (no per-department accounts); no rate limit on the citizen endpoints and no real SMS OTP yet (the mobile login uses a demo PIN); no push notification to officers; no formal DPDP Act review. Phone verification and rate limiting are Phase 2 of the roadmap (06-implementation-plan); SMS OTP is not in the product and is planned once the SMS licence is obtained.

3. Scalability

Concern	Today	Path
Compute	The API is stateless; state lives in Postgres	Run more API instances behind the host's load balancer
New departments	One YAML spec plus office rows; no engine change	A central department registry file with automatic checks (proposed in docs/ARCHITECTURE_DEPARTMENTS.md)
New areas	Offices and wards are database rows, not code	Add verified data per district
LLM capacity	Free-tier limits (about 8,000 tokens per minute per model); the chain of four models absorbs bursts	Paid tier; the engine sends a compact prompt: session state, the active spec and the last messages
Free hosting	Free hosts sleep when idle; Supabase can pause after 7 days idle	Paid plans before any public pilot

Concern	Today	Path
Channels	Website only	The Turn Engine and validator are not website-specific, so WhatsApp or other channels can sit in front of the same core

4. Testing

415 backend and 35 dashboard tests (no network or keys), contract tests shared by the mock and the real API, and live accuracy scripts (`backend/tests/prompt/`) whose results are stored in `submission/` . Model providers rename and retire models, so `.env.example` records when each model name was last checked live.

Samadhan (समाधान) · MPOne Idea & Innovation Hackathon 2026 · Problem Statement 5 · Repo: github.com/krishnakantnagina/Samadhan · Live: samadhan-web.onrender.com